Kiểm thử API và phân quyền

Tài liệu học tập chi tiết · Lý thuyết, ví dụ, thực hành và hướng giải

Vị trí bài học trong khóa

- Khóa học: Kiểm thử phần mềm nhập môn.
- Chương 5: Kiểm thử dữ liệu và dịch vụ.
- Các bài trong chương: Kiểm thử API và phân quyền; Kiểm thử cơ sở dữ liệu và tính toàn vẹn.
- Đọc lý thuyết, tự làm ví dụ rồi đối chiếu hướng giải; sau đó mới làm quiz. Bài thực hành tổng hợp cuối khóa dùng để kết nối kiến thức giữa các chương.

> **Mục tiêu bài học**
>
> Thiết kế ca kiểm thử hợp đồng HTTP và quyền truy cập theo tài khoản.

Kiến thức nền

API test cần kiểm tra phương thức, đường dẫn, tham số, kiểu dữ liệu, mã trạng thái và nội dung phản hồi theo hợp đồng. Mã 200 không đủ chứng minh đúng: cần xác nhận dữ liệu, tác dụng phụ và quyền. Lỗi có thể nằm ở nghiệp vụ dù phản hồi vẫn là JSON hợp lệ.

Phân biệt xác thực danh tính với phân quyền tài nguyên. Kiểm tra người chưa đăng nhập, đúng chủ sở hữu, người khác và vai trò quản trị theo yêu cầu. Thay ID tài nguyên là tình huống kiểm tra quyền ở mức đối tượng quan trọng; chỉ thực hiện trên dữ liệu lab được phép.

Test đầu vào gồm thiếu trường, sai kiểu, giá trị biên và tài nguyên không tồn tại. Không đưa token vào báo cáo hoặc nguồn mã. Tạo dữ liệu test riêng và dọn trong phạm vi đó. Các mã phản hồi cụ thể phụ thuộc hợp đồng API, không suy ra mọi lỗi đều phải cùng một mã.

1. Hợp đồng request và response

Ghi method, path, headers cần thiết, schema body, trạng thái và schema response. Test API không chỉ kiểm tra “có JSON”: một JSON trả danh sách tài nguyên của người khác vẫn là sai quyền. Không ghi token vào fixture công khai hoặc ảnh minh chứng.

2. Mẫu yêu cầu minh họa

```
POST /api/enrollments
Authorization: Bearer <TOKEN_TEST_KHÔNG_CÔNG_KHAI>
Content-Type: application/json

{"course_id": 513}
```

Đây là mẫu minh họa; trước khi chạy phải đối chiếu endpoint và trường thực tế của môi trường thử. Không tự gửi hàng loạt tới production vì thấy một URL trong tài liệu.

3. Ma trận tài khoản và tài nguyên

```
Người gọi       Tài nguyên                 Kỳ vọng
Chưa xác thực   Bài làm riêng             Từ chối theo hợp đồng
U1              Bài làm U1                 Cho phép
U1              Bài làm U2                 Từ chối, không lộ nội dung
Giảng viên      Bài làm khóa mình phụ trách Theo quy tắc vai trò
```

Kiểm tra cả mã phản hồi lẫn nội dung bị rò rỉ. Trường hợp tài nguyên không tồn tại khác tài nguyên tồn tại nhưng không được phép, dù ứng dụng có thể cố ý dùng cùng phản hồi để giảm tiết lộ thông tin.

4. Bài tập và lời giải

Với API tạo ghi danh, viết test thiếu trường, chuỗi sai kiểu, khóa không tồn tại, lặp và đồng thời. Xác minh không tạo thanh toán với khóa miễn phí, không tạo dữ liệu khi bị từ chối. Hợp đồng có thể chấp nhận một số phép chuyển kiểu nên không tự coi mọi chuỗi số là lỗi nếu chưa xác nhận yêu cầu.

> **Bài tập vận dụng bổ sung**
>
> Lập năm test cho API đăng ký: hợp lệ, khóa không tồn tại, thiếu xác thực, đăng ký trùng và ID sai kiểu. Nêu điều kiện dữ liệu trước/sau, dùng môi trường thử nghiệm.

Hướng giải bài tập bổ sung

Kiểm tra đồng thời mã, schema, quyền và tác dụng dữ liệu. Không ghi token thật vào minh chứng.

Câu hỏi tự kiểm tra

1. API trả 200 đã đủ kết luận đúng nghiệp vụ chưa?
2. Xác thực trả lời câu hỏi nào?
3. Phân quyền trả lời câu hỏi nào?
4. Đổi ID sang tài nguyên của tài khoản khác nhằm kiểm tra gì?
5. Token test nên được quản lý thế nào?

Gợi ý đáp án và điểm cần nhớ

- Chưa, cần kiểm tra nội dung và dữ liệu. Thành công HTTP không bảo đảm kết quả nghiệp vụ đúng.
- Người gọi là ai. Authentication xác định danh tính.
- Người gọi được phép truy cập gì. Authorization áp dụng quyền trên thao tác và tài nguyên.

- Quyền ở mức đối tượng. Server phải kiểm tra quyền với tài nguyên được yêu cầu.
- Giữ bí mật và không đưa vào báo cáo. Token là thông tin xác thực cần bảo vệ.

Cách tự đánh giá sau bài

- Giải thích được thuật ngữ mà không đọc lại định nghĩa.
- Thực hiện lại ví dụ với dữ liệu khác và nêu được giới hạn áp dụng.
- Hoàn thành bài tập, đối chiếu bằng chứng hoặc đầu ra với hướng giải.
- Nếu còn nhầm, ghi câu hỏi cụ thể để hỏi giảng viên hoặc AI Tutor cùng ngữ cảnh bài.

Các câu tự kiểm tra có thể trùng trọng tâm quiz. Làm đúng câu đã đọc không tự chứng nhận thành thạo; cần thêm bài vận dụng và minh chứng thực hành.

Tài liệu đọc thêm

- https://istqb.org/wp-content/uploads/2024/11/ISTQB_CTFL_Syllabus_v4.0.1.pdf

Kiểm thử API và phân quyền — Thực hành và hỏi đáp

Phần bổ sung cho bài học · biên soạn 29/10/2026

Tình huống, ví dụ và tự kiểm tra

Tình huống: UI ẩn nút nhưng API vẫn cho người khác sửa khóa. Kiểm tra theo vai trò và theo tài nguyên thuộc ai, không chỉ đăng nhập/chưa đăng nhập.

Tự luyện: dùng tài khoản A tạo tài nguyên lab; B thử đọc/sửa/xóa theo hợp đồng. **Hướng giải:** mã từ chối phù hợp và dữ liệu không đổi; một số API dùng 404 để không tiết lộ sự tồn tại. Với AI Tutor, HTTP 200 có thể chứa lỗi LLM hoặc câu từ chối: chấm nội dung, nguồn và phạm vi riêng, không gọi mọi HTTP 200 là câu trả lời tốt.

Nguồn học tiếp

https://docs.pytest.org/en/stable/how-to/assert.html